

Supplementary Materials

BCHAIN-ACCESS: An Accessibility-by-Design Framework Integrating Blockchain and HCI for Healthcare Interfaces

This supplement provides implementation-depth and audit material referenced from the main paper. S1–S3 are development/feasibility artifacts recorded on a local Hardhat EVM node and are not representative of production-network behaviour. S4–S6 support the security, accessibility-conformance, and positioning claims. Cells marked **Confirm** indicate values the authors should finalise against their own audit logs and the public deposit (see the project repository).

S1. Development-Network Gas Benchmarks

Recorded on a local Hardhat EVM node (Solidity 0.8.19, optimizer enabled, 200 runs; 30,000,000 gas block limit; no congestion). Values are average `gasUsed` from the full reference implementation, in which the append-only audit log is written on-chain for HIPAA-style traceability; costs are correspondingly higher than a hash-only design would incur and are *not* representative of mainnet, public-testnet, or Layer-2 costs. ETH estimates are illustrative at 20 Gwei.

Contract Function	EVM Gas	Est. ETH	Category
<code>registerRecord</code>	341,873	≈ 0.0068	Write (storage init + audit)
<code>initiateGrant</code>	386,111	≈ 0.0077	Write (struct setup + audit)
<code>confirmGrant</code>	199,832	≈ 0.0040	Modify (storage update + audit)
<code>cancelPendingGrant</code>	213,328	≈ 0.0043	Modify (pending cleared + audit)
<code>revokeAccess</code>	171,927	≈ 0.0034	Modify (de-activation + audit)
<code>checkAccess</code>	0	0 (free)	Read (view)
<code>getAuditLog</code>	0	0 (free)	Read (view)
<i>(deployment)</i>	2,925,863	≈ 0.0585	Deploy (9.8% of block limit)

Figures are average `gasUsed` over the evaluation workload and reflect the full Solidity implementation, including the on-chain append-only audit-log writes that accompany every state-changing call; `initiateGrant` varied across calls (380,412–400,360, avg. 386,111). Only 32-byte record hashes are stored on-chain; sensitive records remain off-chain.

S2. Threat-Vector-to-Mitigation Matrix

Threat vector	Implemented mitigation
Unauthorized access	<code>accessGrants</code> check + off-chain-encrypted records
Replay attacks	EVM account nonces
Coerced / accidental grants	60s cooldown + <code>cancelPendingGrant()</code>
Audit-log tampering	Append-only <code>AuditEntry[]</code>
Sybil attacks	DAC whitelist model
Front-running of a pending grant	<code>onlyPatient(msg.sender)</code> guard on <code>confirmGrant</code>

S3. Feature-by-Feature Architecture Comparison

Property	Centralized EHR	Pure-Ethereum	BCHAIN-ACCESS
Patient data sovereignty	No	Partial	Yes
PII protection	DB-leak exposure	On-chain string exposure	On-chain hash only
Two-phase time-locked window	No	No	Yes
Immutable audit trail	No	Yes	Yes
Explicit WCAG-2.1-AA UI layer	No	No	Yes
Access-check latency	—	—	<10 ms (view, informal)

S4. Security Threat Model (STRIDE)

STRIDE decomposition of `HealthAccessControl.sol`. “Residual/next step” items are scoped to the independent audit (Limitation L8) and public-testnet evaluation (L7).

STRIDE category	Contract-level exposure	Mitigation / residual
Spoofing (identity)	Impersonating a patient or provider address	EVM account keys + <code>onlyPatient(msg.sender)</code> binding; residual: key-management/HSM out of scope
Tampering (data)	Altering records or grants	On-chain hash anchoring; append-only structures; off-chain records encrypted at rest (Confirm KMS)
Repudiation	Denying a grant/revoke occurred	Append-only <code>AuditEntry[]</code> audit log with immutable event trail
Information disclosure	Leaking PII via chain data	Only 32-byte hashes on-chain; personal data off-chain; salted digests
Denial of service	Blocking access or exhausting gas	<code>view</code> reads are free; bounded loops; residual: public-network gas/DoS under load unmeasured (L7)
Elevation of privilege	Gaining access without patient consent	Single-role <code>onlyPatient</code> modifier; two-phase time-locked confirmation; residual: static analysis (Slither/Mythril) recommended (see S6)

S5. WCAG 2.1 Level AA Conformance Coverage Matrix

Per-criterion coverage of the UI-layer prototype (Levels A + AA = 50 success criteria for AA conformance). Status: **Yes** = implemented with the stated mechanism; *N/A* = not applicable (no such content type); **Confirm** = present in the automated/code-review audit, authors to finalise against logs. (Media criteria 1.2.x are *N/A*: the prototype contains no audio or video.)

SC	Success Criterion (Level)	Status	Mechanism / note
1.1.1	Non-text Content (A)	Yes	Alt text on all images/icons
1.2.1–1.2.5	Time-based media (A/AA)	N/A	No audio/video content
1.3.1	Info & Relationships (A)	Yes	Semantic HTML + ARIA landmarks
1.3.2	Meaningful Sequence (A)	Yes	Logical DOM/reading order
1.3.3	Sensory Characteristics (A)	Yes	Instructions not colour/shape-only
1.3.4	Orientation (AA)	Confirm	Responsive layout
1.3.5	Identify Input Purpose (AA)	Confirm	Autocomplete tokens on inputs
1.4.1	Use of Colour (A)	Yes	Colour not sole indicator
1.4.2	Audio Control (A)	N/A	No auto audio
1.4.3	Contrast (Minimum) (AA)	Yes	29/29 pairs $\geq 4.5:1$ (3:1 large)
1.4.4	Resize Text (AA)	Confirm	Zoom to 200% without loss
1.4.5	Images of Text (AA)	Yes	Real text, not images of text
1.4.10	Reflow (AA)	Confirm	Reflow at 320 CSS px
1.4.11	Non-text Contrast (AA)	Yes	UI components/focus $\geq 3:1$

SC	Success Criterion (Level)	Status	Mechanism / note
1.4.12	Text Spacing (AA)	Confirm	No clipping under spacing override
1.4.13	Content on Hover/Focus (AA)	Confirm	Dismissible/persistent tooltips
2.1.1	Keyboard (A)	Yes	Full keyboard operability
2.1.2	No Keyboard Trap (A)	Yes	Verified no trap
2.1.4	Character Key Shortcuts (A)	N/A	No single-key shortcuts
2.2.1	Timing Adjustable (A)	Confirm	60s cooldown — make user-configurable (open item; see main paper)
2.2.2	Pause, Stop, Hide (A)	N/A	No moving/auto-updating content
2.3.1	Three Flashes (A)	Yes	No flashing; reduced-motion honoured
2.4.1	Bypass Blocks (A)	Yes	“Skip to main content” link
2.4.2	Page Titled (A)	Yes	Descriptive title
2.4.3	Focus Order (A)	Yes	Logical focus order
2.4.4	Link Purpose (In Context) (A)	Yes	Descriptive link text
2.4.5	Multiple Ways (AA)	Confirm	Nav + direct actions
2.4.6	Headings & Labels (AA)	Yes	Descriptive headings/labels
2.4.7	Focus Visible (AA)	Yes	Visible focus indicators
2.5.1–2.5.4	Pointer/Motion (A)	Confirm	No path/motion-only gestures
3.1.1	Language of Page (A)	Yes	lang attribute set
3.1.2	Language of Parts (AA)	N/A	Single-language content
3.2.1	On Focus (A)	Yes	No context change on focus
3.2.2	On Input (A)	Yes	No unexpected change on input
3.2.3	Consistent Navigation (AA)	Yes	Consistent nav across views
3.2.4	Consistent Identification (AA)	Yes	Consistent component labels
3.3.1	Error Identification (A)	Yes	Errors announced + identified
3.3.2	Labels or Instructions (A)	Yes	Labels/instructions on inputs
3.3.3	Error Suggestion (AA)	Confirm	Correction guidance on errors
3.3.4	Error Prevention (Legal/Fin/Data) (AA)	Yes	Two-stage confirmation + time-lock + cancel
4.1.1	Parsing (A)	Yes	Valid markup
4.1.2	Name, Role, Value (A)	Yes	ARIA name/role/value on components
4.1.3	Status Messages (AA)	Yes	ARIA live regions announce updates

Note. 2.2.1 (Timing Adjustable) is the one open conformance item: the 60s window is currently fixed and is flagged in the main paper as requiring user-configurability; two evaluators (E7, E9) independently raised it. It is the top remediation item for the next iteration.

S6. Static Analysis (Slither)

slither was run against `HealthAccessControl.sol` (solc 0.8.19); the full JSON report is deposited at `analysis/slither_report`. All High and Medium findings were reviewed and determined to be false positives for this contract’s usage; no change to contract behaviour was required.

Severity	Count	Detector(s)	Resolution
High	1	weak-prng	False positive: <code>block.timestamp</code> is used only for the 60s consent time-lock and for audit-log timestamps, never as a source of randomness; no value or branch depends on unpredictable entropy.
Medium	1	incorrect-equality	Reviewed: strict equality is applied only to explicit sentinel checks (e.g. <code>grant.expiration == 0</code> , denoting “no expiry”), never to balances or block timestamps; no exploitable path.
Low	10	timestamp, shadowing-local, events-access	<code>block.timestamp</code> dependence is intrinsic to the documented time-lock design (L7); local shadowing and missing ownership events are non-security style items.
Informational	38	solc-version, naming-convention, boolean-equal	Style/versioning only; no functional or security impact.

Static analysis is a floor, not a substitute for professional audit; the contract remains unaudited by an independent third party (Limitation L8). Record the exact Slither and solc versions and run date alongside the deposited report.